



**Office of Trade**  
**Trade Solutions Pilot**  
**Statement of Work**  
**(SOW) June 27, 2025**

THIS PAGE INTENTIONALLY LEFT BLANK

# Table of Contents

|            |                                                                                      |                                     |
|------------|--------------------------------------------------------------------------------------|-------------------------------------|
| <b>1.0</b> | <b>BACKGROUND .....</b>                                                              | <b>4</b>                            |
| <b>2.0</b> | <b>SCOPE.....</b>                                                                    | <b>5</b>                            |
| <b>3.0</b> | <b>PERIOD OF PERFORMANCE .....</b>                                                   | <b>6</b>                            |
| <b>5.0</b> | <b>TYPE OF CONTRACT .....</b>                                                        | <b>6</b>                            |
| <b>6.0</b> | <b>POINTS OF CONTACT.....</b>                                                        | <b>6</b>                            |
| <b>7.0</b> | <b>DELIVERABLES AND SUPPORT .....</b>                                                | <b>6</b>                            |
| <b>8.0</b> | <b>COMPLIANCE REQUIREMENTS .....</b>                                                 | <b>7</b>                            |
| 8.1        | <i>INFORMATION TECHNOLOGY SECURITY COMPLIANCE REQUIREMENTS.....</i>                  | 7                                   |
| 8.1.1      | <i>DHS Security Policy Compliance Requirements .....</i>                             | 7                                   |
| 8.1.2      | <i>Basic Requirements .....</i>                                                      | 7                                   |
| 8.1.3      | <i>Security Authorization .....</i>                                                  | 8                                   |
| 8.1.4      | <i>Encryption Compliance Requirement .....</i>                                       | 9                                   |
| 8.1.5      | <i>Security Review.....</i>                                                          | 9                                   |
| 8.1.6      | <i>Enterprise Security Architecture .....</i>                                        | 10                                  |
| 8.1.7      | <i>Information Assurance .....</i>                                                   | 10                                  |
| 8.1.8      | <i>Continuous Monitoring .....</i>                                                   | 10                                  |
| 8.1.9      | <i>Specific Protections.....</i>                                                     | 11                                  |
| 8.1.10     | <i>Security Requirements for Unclassified Information Technology Resources .....</i> | 12                                  |
| 8.1.11     | <i>Other Security Requirements .....</i>                                             | 13                                  |
| 8.1.12     | <i>Management .....</i>                                                              | 13                                  |
| 8.2        | <i>Technical Compliance Requirements.....</i>                                        | 13                                  |
| 8.2.1      | <i>AI/ML Algorithm Requirements.....</i>                                             | 13                                  |
| 8.2.1.1    | <i>Specific Algorithm Parameters.....</i>                                            | <b>Error! Bookmark not defined.</b> |
| 8.2.1.2    | <i>Architecture/Integration Parameters.....</i>                                      | 13                                  |
| 8.2.1.3    | <i>Data Requirements.....</i>                                                        | 13                                  |
| 8.2.1.4    | <i>Desired Level of Algorithm Rights .....</i>                                       | <b>Error! Bookmark not defined.</b> |
| 8.2.2      | <i>Integration Compliance Requirements.....</i>                                      | 14                                  |
| 8.2.2.1    | <i>Infrastructure .....</i>                                                          | 14                                  |
| 8.2.2.2    | <i>Standard Network Compliance Requirements .....</i>                                | 14                                  |
| 8.2.2.3    | <i>Other Critical Compliance Requirements .....</i>                                  | 14                                  |
| 8.2.3      | <i>DHS-CBP Enterprise Architecture Compliance Requirements.....</i>                  | 16                                  |
| 9.0        | <i>Accessibility Requirements (Section 508 Compliance).....</i>                      | 17                                  |
| 9.1        | <i>Section 508 Requirements for Technology Services.....</i>                         | 17                                  |
| 9.2        | <i>Section 508 Deliverables.....</i>                                                 | 19                                  |
| 10.0       | <i>DHS Information Technology Portfolio Alignment .....</i>                          | 19                                  |

## **Department of Homeland Security Customs & Border Protection (CBP) Statement of Work (SOW) for Trade Solutions Pilot**

### **1.0 BACKGROUND**

U.S. Customs and Border Protection's (CBP) mission is to "Protect the American people, safeguard our borders, and enhance the nation's economic prosperity", with a corresponding vision statement of "Enhancing the nation's security through innovation, intelligence, collaboration and trust." CBP operates under an enforcement mandate and our responsibilities extend to additional functions like security screening, tariff enforcement, anti-smuggling, fraud prevention, and interagency coordination for 500+ trade laws and regulations across 47 different agencies.

The National Customs Automation Program (NCAP) was established by Subtitle B of Title VI—Customs Modernization, in the North American Free Trade Agreement Implementation Act (Customs Modernization Act) (Pub. L. 103-182, 107 Stat. 2057, 2170, December 8, 1993) ([19 U.S.C. 1411](#)). Through the NCAP, the thrust of customs modernization was focused on trade compliance and the development of the Automated Commercial Environment (ACE), the successor to the Automated Commercial System (ACS). ACE is an automated and electronic system for commercial trade processing, intended to streamline business processes, facilitate growth in trade, ensure cargo security, and foster participation in global commerce, while facilitating compliance with U.S. laws and regulations and reducing costs for U.S. Customs and Border Protection (CBP) and all of its communities of interest.

CBP currently faces a rapidly evolving global trade landscape that requires new technology approaches and operational methods. The volume of small packages in the de minimis environment combined with recent changes to de minimis rules presents opportunities for the private sector and for CBP to improve efficiency, lower costs, and maximize revenue collection. Current challenges include high barriers to classify products for tariff calculations, managing evolving import risks, innovating revenue collection methods, and limited visibility into supply chains. The ability to meet CBP's mission objectives depends on successfully modernizing CBP's business functions and the information technology that supports those functions. CBP's modernization efforts are accomplished through phased releases of ACE component functionality, which update the system and add new functionality. The Customs Modernization Act authorizes the Commissioner of CBP to conduct limited test programs or procedures designed to evaluate planned components of the NCAP.

As CBP faces a growing need for more information, there exists private sector trade compliance platforms and technologies designed to support importers, exporters, and freight forwarders with commercial documentation, denied party screening, tariff calculation, and partner agency filing. These systems are typically optimized for transactional efficiency, cost savings, and regulatory compliance from a private sector business perspective. Access to the data contained in private sector trade compliance platforms can greatly assist in CBP's targeting efforts, allocation of operational resources, and overall mission efficiency. They can also help bolster benefits given to Trusted Trader designations in program such as the Customs Trade Partnership Against Terrorism. CBP is interested in technology solutions that improve industry compliance and/or provide new enforcement insights to CBP that allow for improved risk segmentation. Gaining access to private sector trade compliance data presents opportunities for both the private sector and for CBP to improve efficiency, lower costs, and maximize revenue collection.

## 2.0 SCOPE

CBP will assess commercial solutions that integrate with CBP's Automated Commercial Environment (ACE). The development and implementation of these private sector solutions, which will be conducted via a test environment within ACE, will enable CBP to explore how cutting-edge solutions already in use by the private sector may be leveraged by the U.S. government to streamline operations, promote cargo security and compliance, and secure tariff revenue.

Under Department of Homeland Security (DHS) Commercial Solution Opening Pilot Program (CSOP), CBP will explore cutting-edge technologies that solve one or more capability pillars:

- Pillar 1: Artificial Intelligence (AI)-driven solutions that address one or more of the following: automated tariff classification, value and country of origin validations; earlier tariff collection and payment to the U.S. Government, especially in the international mail environment; and supply chain tracing solutions that improve visibility and risk segmentation of imports and supply chain actors before shipments arrive in the U.S.
- Pillar 2: Technology solutions that enable electronic direct filing of entry/entry summary information with CBP to reduce existing competitive barriers faced by small/medium sized businesses who may lack financial resources to employ reliable Licensed Customs Broker services.
- Pillar 3: Existing technology solutions that could be used to develop an international customs platform accessible to World Customs Organization (WCO) members.

If awarded a contract, over the course of this intended CSOP piloting program, CBP will assess:

- The interoperability of the proposed commercial solutions with CBP's IT infrastructure, allowing seamless ingestion of the information CBP needs to execute its enforcement mission.
- Feasibility of the proposed commercial solutions to test one or more of the below services:
  - U.S. Government collection of international mail data prior to shipment arrival
  - At-scale pre-vetting of customers, products, and/or the physical security of goods
  - Accurate AI-enabled tariff classification of products
  - Enhanced supply chain tracing and insight into parties, production methods, and the movement of goods
  - Improved CBP risk management to better manage the volume of small packages
  - Self-filing of entry/entry summary information for small / medium sized companies via business-to-government solutions
  - Secure third-party receipt of data that seamlessly allow publicly available export data from foreign customs agencies to be ingested by CBP.

The solutions delivered under this SOW must drive enhancements and efficiencies around tariff classification, import risk management, tariff revenue collection, and/or supply chain tracing. The desired end state for this SOW is direct transmission into ACE of trade data, entity data, and AI driven insights that support CBP's enforcement mandates, collection of revenue, identification of high-risk shipments, and expedited processing of low-risk imports—all without exposure to CBP stored PII and law enforcement sensitive algorithms and targeting models. The solutions should increase the thoroughness and/or reduce the time needed overall to conduct

import or entity reviews, segment risk, and reduce CBP personnel manpower and resource commitments to sustain high volume operations such as low-value package reviews.

A core tenet of this exploratory effort is to increase CBP's agility to more efficiently evaluate, implement, and leverage cutting-edge innovations developed by the private sector. As a result, CBP is especially interested in exploring solutions that may use alternative methods other than CBP's existing Electronic Data Interchange (EDI) standards of electronic data transmission to CBP's Automated Commercial Environment (ACE). Exploring modern solutions that enable secure data transmissions to CBP systems will allow the agency to be more nimble and resourceful in adopting cutting-edge technology.

~~Responses to this solicitation should: not exceed 10 pages; indicate which of the above capability pillar(s) the services are intended to address; identify how the proposed services meet the objectives of the pillar(s); and clearly disclose all anticipated costs to the Government.~~

~~Interested vendors must be willing and prepared to conduct demonstrations of their capabilities shortly after submitting written responses to this solicitation. At the conclusion of this procurement process, CBP may select several viable candidates to proceed with as part of an ongoing pilot via a test environment within CBP's ACE. The pilot may ultimately inform minimum security criteria and certifications of vendors approved to submit data transmissions to CBP for the purposes outlined in the three capability pillars.~~

### **3.0 PERIOD OF PERFORMANCE**

The contract period of performance is intended to be one base year and may contain options.

### **5.0 TYPE OF CONTRACT**

This award will establish a Non-FAR Contract through the DHS Commercial Solution Opening Pilot Program (CSOP).

### **6.0 POINTS OF CONTACT**

Contracting Officer: Peter Giambone

Email: [peter.a.giambone@cbp.dhs.gov](mailto:peter.a.giambone@cbp.dhs.gov)

### **7.0 DELIVERABLES AND SUPPORT**

The scope shall include the following capabilities, which may be iteratively developed at the Task and Solutions level of the contract. All deliverables shall be delivered to the email address that will be provided after award.

a) CBP will explore cutting-edge technologies that solve one or more capability pillars:

- **Pillar 1:** Solutions CBP may eventually certify to interface with CBP systems and provide key services, including:
  - AI-enabled solutions to drive automated tariff classification, value and country of origin validations, etc.
  - Earlier tariff collection and payment to the U.S. Government especially in the international mail environment.
  - Supply chain tracing solutions to improve visibility and risk segmentation of

imports and supply chain actors before shipments arrive in the U.S.

- **Pillar 2:** Solutions that enable electronic direct filing of entry/entry summary information with CBP to reduce existing competitive barriers faced by small/medium sized businesses who may lack financial resources to employ reliable Licensed Customs Broker services.
- **Pillar 3:** Existing technology solutions that could be used to develop an international customs platform accessible to World Customs Organization (WCO) members.

b) Services, if applicable, which may include:

1. Expanded Feature Development (Product development features to support CBP operations). Government may require the contractors support in expanding CBP's capability by helping it develop additional add on features or enhancements as the need arises.
2. Training to support deployment, use, and upgrades.

### **Contract Data Requirements**

|     |     |     |
|-----|-----|-----|
| TBD | TBD | TBD |
|-----|-----|-----|

## **8.0 COMPLIANCE REQUIREMENTS**

### ***8.1 Information Technology Security Compliance Requirements***

The contractor shall adhere to all DHS and CBP IT security policies and the basic requirements, security authorization, encryption compliance, and pass security review.

#### ***8.1.1 DHS Security Policy Compliance Requirements***

All hardware, software, and services provided under this CSOP contract must be compliant with DHS 4300A, the DHS Management Directive 140-01, and Information Security Program and CBP Information Systems Security Policies and Procedures Directive, HB 1400-05D. Any solution presented that includes artificial intelligence (AI), machine learning (ML), or large language model (LLM) components must adhere to guidance outlined in DHS's Artificial Intelligence System Security Guide (March 2025 - version 3.0).

#### ***8.1.2 Basic Requirements***

The contractor shall adhere to all DHS and CBP IT security policies listed in the applicable documents section, including the guidelines and policies stated in the DHS Sensitive Systems Policy Directive 4300A or any subsequent, replacement or revised publication. This policy mandates DHS organizational elements, including contractors, follow guidelines outlined in the DHS MD 4300A, DHS Sensitive Systems Directive, Information Technology Security Program, Version 13, with attachments or any subsequent, replacement or revised publication.

DHS Directive 4300A, Basic Requirements outlines the management, operational and technical baseline security requirements (BLSR) for DHS Components to ensure confidentiality, integrity, availability, authenticity, and non-repudiation of sensitive information systems. The 4300A Directive provides greater detail of the BLSRs, including the roles and responsibilities associated with each.

CBP will provide personnel with the appropriate background investigation, clearance levels to support the security certification/accreditation processes under this Agreement in accordance with DHS MD 4300A, DHS Sensitive Systems Policy and Directive. During all systems development life cycle (SDLC) phases of CBP systems, CBP personnel will develop documentation and provide any required information for all levels of classification in support of the certification/accreditation process. In addition, all security certification/accreditation will be performed using the DHS certification/accreditation process, methodology and tools. systems development life cycle (SDLC) phases of CBP systems, CBP personnel will develop documentation and provide any required information for all levels of classification in support of the certification/accreditation process. In addition, all security certification/accreditation will be performed using the DHS certification/accreditation process, methodology and tools.

Legacy air gapped non-integrated systems shall:

- a) Wi-Fi shall not be used and be disabled.
- b) All operating systems must use the requisite DHS Security Technical Implementation Guides (STIGs) for hardening configurations.
- c) All vendor contractors shall not remove image data from systems nor store said data on contractor networks.
- d) Ground-truthing or tuning of systems will be performed only on CBP systems and not on contractor networks unless specifically authorized.
- e) Integrated networked systems shall follow the above requirements and additionally:
  - o If systems are using WIFI the design must be explicitly reviewed and approved by the CBP EIOD organization and Security and Technology Policy (STP).
- f) Other wireless connectivity may be approved by EIOD
- g) Systems must be patched and security updates maintained according to DHS patching standards (within 30 days usually) CBP Information Systems Security Policies and Procedures, Information Security Continuous Monitoring guidelines.
- h) Username/Password authentication is not allowed.

### *8.1.3 Security Authorization*

- a) A Security Authorization of any infrastructure directly in support of the DHS information system shall be performed by the contractor as a general support system (GSS) prior to DHS occupancy to characterize the network, identify threats, identify vulnerabilities, analyze existing and planned security controls, determine likelihood of threat, analyze impact, determine risk, recommend controls, perform remediation on identified deficiencies, and document the results. The Security Authorization shall be performed in accordance with the DHS Security Policy and the controls provided by the hosting provider shall be equal to or stronger than the Federal Information Processing Standards (FIPS) 199, Standards for Security Categorization of Federal Information and Information Systems, Section 3, security categorization of the DHS information system.
- b) At the beginning of the contract, and annually thereafter, the contractor shall provide the results of an independent assessment and verification of security controls in the contractor's format. The independent assessment and verification shall apply the same standards that DHS applies in the Security Authorization Process of its information systems. Any deficiencies noted during this assessment shall be provided to the Contracting Officer Representative (COR) for entry into the DHS Plan of Action and Milestone (POA&M) Management Process. The



contractor shall use the DHS POA&M process to document planned remedial actions to address any deficiencies in information security policies, procedures, and practices, and the completion of those activities. Security deficiencies shall be corrected within the timeframes dictated by the DHS POA&M Management Process. contractor procedures shall be subject to periodic, unannounced assessments by DHS officials. The physical aspects associated with contractor activities shall also be subject to such assessments.

- c) On a periodic basis, the DHS and its components, including the DHS Office of Inspector General, may choose to evaluate any or all of the security controls implemented by the contractor under these clauses. Evaluation could include but is not limited to vulnerability scanning. The DHS and its Components reserve the right to conduct audits at their discretion. With ten working days' notice, at the request of the Government, the contractor shall fully cooperate and facilitate in a Government-sponsored security control assessment at each location wherein DHS information is processed or stored, or information systems are developed, operated, maintained, or used on behalf of DHS, including those initiated by the Office of the Inspector General. The government may conduct a security control assessment on shorter notice (to include unannounced assessments) determined by DHS in the event of a security incident.

#### *8.1.4 Encryption Compliance Requirement*

- a) Systems requiring encryption shall comply with FIPS 197 Advanced Encryption Standard (AES) 256 algorithm and cryptographic modules that have been validated under FIPS 140-2.
- b) Systems requiring encryption shall comply with National Security Agency (NSA) Type 2 or Type 1 encryption.
- c) Only cryptographic modules that are FIPS 197 (AES 256) compliant and have received FIPS 140-2 validation at the level appropriate to their intended use may be used in systems requiring encryption.
- d) Public Key Infrastructure (PKI) (see the Department of Homeland Security (DHS) Sensitive Systems Policy Directive 4300A).

#### *8.1.5 Security Review*

The Government may elect to conduct periodic reviews to ensure that the security requirements contained in this contract are being implemented and enforced. The contractor shall afford DHS including the organization of the DHS Office of the Chief Information Officer, Office of Inspector General, the CBP Chief Information Security Officer, authorized COR, and other Government oversight organizations, access to the Contractor's and subcontractor's facilities, installations, operations, documentation, databases, and personnel used in the performance of this contract. The contractor will contact the DHS Chief Information Security Officer to coordinate and participate in the review and inspection activity of Government oversight organizations external to the DHS. The contractor shall provide access to the extent necessary for the Government to carry out a program of inspection, investigation, and audit to safeguard against threats and hazards to the integrity, availability, and confidentiality of DHS/CBP data or the function of computer systems operated on behalf of DHS/CBP, and to preserve evidence of computer crime.

#### *8.1.6 Enterprise Security Architecture*

The contractor shall utilize and adhere to the DHS Enterprise Security Architecture in accordance with applicable laws and DHS policies to the satisfaction of the DHS COR. Areas of consideration could include:

- a) Use of multi-tier design (separating web, application, and data base) with policy enforcement between tiers
- b) Compliance to DHS Identity Credential and Access Management (ICAM)
- c) Security reporting to DHS central control points (i.e., the DHS Enterprise Security Operations Center (ESOC) and integration into DHS Security Incident Response
- d) Integration into DHS Change Management (for example, the Infrastructure Change Control Board (ICCB) process)
- e) Performance of security maintenance activities per continuous monitoring requirements

#### *8.1.7 Information Assurance*

Information Assurance (IA) is considered a requirement for all systems used to input, process, store, display, or transmit sensitive or national security information. IA is achieved through the acquisition and appropriate implementation of evaluated or validated commercial-off-the-shelf (COTS) IA and IA-enabled Information Technology (IT) products. These products provide for the availability of systems. The products also ensure the integrity and confidentiality of information and the authentication and nonrepudiation of parties in electronic transactions.

Strong preference is given to the acquisition of COTS IA and IA-enabled IT products (to be used on systems entering, processing, storing, displaying, or transmitting sensitive information) that have been evaluated and validated by authorized commercial laboratories or by National Institute of Standards and Technology (NIST), as appropriate, in accordance with the following:

- a) The NIST Federal Information Processing Standards (FIPS) validation program
- b) The National Security Area (NSA) /NIST National Information Assurance Partnership (NIAP) Evaluation and Validation Program
- c) The International Common Criteria for Information Security Technology Evaluation Mutual Recognition Agreement

#### *8.1.8 Continuous Monitoring*

The contractor shall participate in DHS Continuous Monitoring Strategy and methods or shall provide a Continuous Monitoring capability that the DHS determines acceptable. The DHS Chief Information Security Officer (CISO) issues annual updates to its Continuous Monitoring requirements via the Annual Information Security Performance Plan. At a minimum, the contractor shall implement the following processes:

- a) Asset Management
- b) Vulnerability Management
- c) Configuration Management
- d) Malware Management
- e) Log Integration
- f) Security Information Event Management (SIEM) Integration

#### g) Patch Management

The contractor shall provide near-real-time security status information to the DHS ESOC. The contractor shall establish a monitoring scope at least as comprehensive and stringent as described in DHS 4300A Sensitive Systems Directive, "Incident Response."

#### 8.1.9 *Specific Protections*

Specific protections that shall be provided by the contractor include, but are not limited to the following:

- a) **Intrusion Detection Systems and Monitoring** - The contractor shall provide the design, configuration, implementation, and maintenance of the sensors and hardware that are required to support the Network Intrusion Detection System (NIDS) solution. The contractor is responsible for creating and maintaining the NIDS rule sets. The NIDS solution should provide real-time alerts. These alerts and other relevant information shall be located in a central repository. The NIDS shall operate 24x7x365. A summary of alerts shall be reported to the DHS COR in weekly status reports. If an abnormality or anomaly is identified, the contractor shall notify the appropriate DHS point of contact in accordance with the incident response plan.
- b) **Physical and Information Security and Monitoring** - The contractor shall provide a facility using appropriate protective measures to provide for physical security. The facility will be located within the United States and its territories. The contractor shall maintain a process to control physical access to DHS IT assets. DHS IT Assets shall be monitored 24x7x365. A summary of unauthorized access attempts shall be reported to the appropriate DHS security office.
- c) **Vulnerability Assessments** - The contractor shall provide all information from any managed device to DHS, as requested, and shall assist, as needed, to perform periodic vulnerability assessments of the network, operating systems, and applications to identify vulnerabilities and propose mitigations. Vulnerability assessments shall be included as part of compliance with the continuous monitoring of the system.
- d) **Anti-malware (e.g., virus, spam)** - The contractor shall design, implement, monitor and manage a comprehensive anti-malware service. The contractor shall provide all maintenance for the system providing the anti-malware capabilities to include configuration, definition updates, and comply with DHS' configuration management / release management requirements when changes are required. A summary of alerts shall be reported to DHS COR in weekly status reports. If an abnormality or anomaly is identified, the contractor shall notify the appropriate DHS point of contact in accordance with the incident response plan.
- e) **Patch Management** - The contractor shall perform patch management services. The contractor shall push apply patches that are required by vendors and the DHS system owner. This is to ensure that the infrastructure and applications that directly support the DHS information system are current in their release and that all security patches are applied. The contractor shall be informed by DHS which patches are required by DHS through the Information Security Vulnerability Management bulletins and advisories. Core applications, the ones DHS utilizes to fulfill their mission, shall be tested by DHS. However, the contractor shall be responsible for deploying patches as directed by DHS. It is recommended that all other applications (host-based intrusion detection system (HIDS), network intrusion detection system (NIDS), Anti-malware, and Firewall shall be tested by the contractor prior to deployment in a test environment.

- f) Log Retention - Log files for all infrastructure devices, physical access, and anti-malware should be retained online for 180 days and offline for three years.

#### 8.1.10 *Security Requirements for Unclassified Information Technology Resources*

- a) The contractor shall be responsible for Information Technology (IT) security for all systems connected to a DHS network or operated by the contractor for DHS, regardless of location. This clause applies to all or any part of the contract that includes information technology resources or services for which the contractor must have physical or electronic access to sensitive information contained in DHS unclassified systems that directly support the agency's mission.
- b) The contractor shall provide, implement, and maintain an IT Security Plan. This plan shall describe the processes and procedures that will be followed to ensure appropriate security of IT resources that are developed, processed, or used under this contract.

(b.1) Within 30 days after contract award, the contractor shall submit for approval its IT Security Plan in the Contractor's format, which shall be consistent with and further detail the approach contained in the officer's Quote. The plan, as approved by the Contracting Officer, shall be incorporated into the contract as a compliance document.

(b.2) The Contractor's IT Security Plan shall comply with Federal laws that include, but are not limited to, the Computer Security Act of 1987 (40 USC 1441 et seq.), sections 5 and 6; the Federal Information Security Management Act (44 USC 3554 (b)) of 2014; and with Federal policies and procedures that include, but are not limited to, OMB Circular A-130, Appendix III, A.3.b (2).

(b.3) The security plan shall specifically include instructions regarding handling and protecting sensitive information at the Contractor's site (including any information stored, processed, or transmitted using the Contractor's computer systems), and the secure management, operation, maintenance, programming, and system administration of computer systems, networks, and telecommunications systems.

- c) Examples of tasks that require security provisions include -
  - (c.1) Acquisition, transmission or analysis of data owned by DHS with significant replacement cost should the Contractor's copy be corrupted; and
  - (c.2) Access to DHS networks or computers at a level beyond that granted the general public (e.g., such as bypassing a firewall).
- d) At the expiration of the contract, the contractor shall return all sensitive DHS information and IT resources provided to the contractor during the contract and certify that all non-public DHS information has been purged from any Contractor- owned system. Components shall conduct reviews to ensure that the security requirements in the contract are implemented and enforced.
- e) Within 6 months after contract award, the contractor shall submit written proof, in the Contractor's format, of IT Security accreditation to DHS for approval by the DHS Contracting Officer. Accreditation will proceed according to the criteria of the DHS Sensitive System Policy Publication, 4300A, or any replacement publication, which the Contracting Officer will provide upon request. This accreditation will include a final security plan, risk assessment, security test and evaluation, and disaster recovery plan/continuity of operations plan. This accreditation, when accepted by the Contracting Officer, shall be incorporated into

the contract as a compliance document. The contractor shall comply with the approved accreditation documentation.

#### *8.1.11 Other Security Requirements*

The contractor shall implement the minimum set of security requirements detailed below:

- a) All systems shall follow DHS/CBP requirements for Defense Information System Agency Security Technical Implementation Guide (DISA STIG) compliance.
- b) All systems shall be capable of operating with CBP security applications and agents, such as Tenable Nessus, Tanium, Splunk, Digital Guardian, and Symantec Endpoint Protection.
- c) All systems shall use TLS v1.2 or higher, encryption protocol when communicating over a network with internal and external systems and components.
- d) All systems shall not use unauthorized programs and unsecure transfer protocols, such as ftp, telnet, http, and peer-to-peer networking.
- e) All systems and network components shall be scanned for vulnerabilities at frequencies designated by CBP and PSPD, at 1-week, 2-week, or 1-month intervals. Based on the findings of the scan, the contractor shall remedy the vulnerability within 30 days.
- f) All system and network component vulnerabilities shall be remediated within 30 days of discovery and documented in a plan of action and milestones (POA&M) if unresolvable within 30 days.
- g) All systems shall have an adjudicated Privacy Threshold Analysis (PTA), Privacy Impact Assessment (PIA), Authority to Test (ATT) and/or Authority to Operate (ATO) for production deployment and operations.
- h) All systems shall have an adjudicated and approved Interconnection Security Agreement (ISA) prior to establishing communications with and sending data to external entities.

#### *8.1.12 Management*

- a) Data cannot be viewed by non-US citizens or leave the United States boundary.
- b) All contractors working with the data must be US citizens.

### **8.2 Technical Compliance Requirements**

#### *8.2.1 AI/ML Algorithm Requirements*

- Any solution presented that includes artificial intelligence (AI), machine learning (ML), or large language model (LLM) components must adhere to guidance outlined in DHS's Artificial Intelligence System Security Guide (March 2025 - version 3.0).

##### *8.2.1.1 Specific Algorithm Parameters*

##### *8.2.1.2 Architecture/Integration Parameters*

Must adhere to CBP Reference Architecture guidelines for all hardware specifications and required software. Any required software outside of CBP authorization, must go through the recommended CBP acquisition process, security testing, and vetting.

##### *8.2.1.3 Data Requirements*

- a) Vendor shall use common data formats for inference and training (e.g., JSON, etc.).
- b) Vendor will not use proprietary input/output data formats. Formats should follow WCO UFF standards.

## *8.2.2 Integration Compliance Requirements*

### *8.2.2.1 Infrastructure*

All systems and services shall meet DHS Enterprise Architecture (EA) policies, standards, and procedures. Specifically, the contractor shall comply with the following Homeland Security (HLS) EA requirements:

- a) All developed systems and requirements shall be compliant with the HLS EA principles.
- b) All IT hardware and software shall be compliant with the HLS EA Technical Reference Model (TRM) Standards and Products Profile.
- c) All products are subject to DHS EA approval. No products may be utilized in any production environment that are not included in the HLS EA TRM Standards and Products Profile.
- d) Description information for all data assets, information exchanges, and data standards, whether adopted or developed, shall be submitted to the Enterprise Data Management Office (EDMO) for review, approval, and insertion into the DHS Data Reference Model and EA Information Repository.
- e) Development of data assets, information exchanges, and data standards will comply with the DHS Data Management Policy MD 103-01 and all data-related artifacts will be developed and validated according to DHS data management architectural guidelines.
- f) Applicability of Internet Protocol Version 6 (IPv6) to DHS-related components (networks, infrastructure, and applications), specific to individual acquisitions, shall be in accordance with the DHS EA (per OMB Memorandum M-05-22, August 2, 2005), regardless of whether the acquisition is for modification, upgrade, or replacement.
- g) All EA-related component acquisitions shall be IPv6 compliant, as defined in the U.S. Government Version 6 (USGv6) Profile (National Institute of Standards and Technology (NIST) Special Publication 500-267) and the corresponding declarations of conformance defined in the USGv6 Test Program.

### *8.2.2.2 Standard Network Compliance Requirements*

Proposed solutions must comply with following CBP network engineering requirements:

- a) Network traffic from untrusted sources sent into the CBP network shall adhere to the CBP network architecture standards, including but not limited to, firewalls, IDS/IPS, DMZ, etc.
- b) No bulk data traffic can be sent to the CBP network without prior knowledge and notification to CBP network personnel.
- c) Not initiate network traffic which will oversubscribe CBP network components, violate CBP security policy, or comprise the integrity of the CBP network architecture.
- d) Must collaborate with all stakeholders to test all Cloud-related systems and to verify that the systems meet requirements and are able to host applications with no degradation to network performance or security to existing applications in cloud or on Prem.

### *8.2.2.3 Other Critical Compliance Requirements*

The contractor shall comply with the following critical compliance requirements:

- a) Accessibility - Section 508 of the Rehabilitation Act requires federal government departments and agencies to ensure all Electronic Information and Technology (EIT) is accessible to people with disabilities. The contractor shall ensure all tasks to design, develop, deploy, operate, and maintain equipment or systems and the systems themselves are in compliance with Section 508 requirements.

- b) IT Security Requirements – Ensuring confidentiality, integrity, availability, and authenticity of sensitive data within the DHS IT infrastructure and operations is a foundational element of the CBP mission. The contractor shall ensure that all tasks to design, develop, deploy, operate, and maintain equipment or systems and the systems themselves are in compliance with DHS-4300A. The contractor shall implement multi-factor authentication (Homeland Security Presidential Directive-12, HSPD-12) for network and endpoint device access and ensure that all equipment configurations follow DISA STIGs as required by DHS.
- c) Interconnection Security Agreements (ISA) –Interconnection Security Agreements (ISA) are required by DHS policy to establish individual and organizational security responsibilities for the protection and handling of unclassified information. An ISA must be in place to allow connectivity between CBP systems and external participating government agencies and non-government entities via the CBP network. The contractor shall ensure all required ISAs are in compliance with DHS 4300A, and NIST Special Publications SP 800-47 and SP 800-53.
- d) Systems Engineering Life Cycle - The DHS SELC is a technical framework that enables consistent management and supports the efficient and effective delivery of capabilities to end-users. The contractor shall ensure that all tasks to design, develop, deploy, operate, and maintain equipment or systems conform to the requirements of DHS Directive 102. The contractor shall adapt all CBP OIT Agile methodologies to comply with DHS SELC requirements, and draft requisite program and technical documentation for all projects per SELC requirements.
- e) CBP Enterprise Architecture – The contractor shall ensure that all tasks to design, develop, deploy, operate, and maintain equipment or systems conform to the DHS/CBP Enterprise Architecture (EA), Technical Reference Models (TRM) and other DHS and CBP policies and guidelines including the CBP Information Technology Enterprise Principles and the DHS Service Oriented Architecture - Technical Framework.
- f) DHS Geospatial Information Systems – The DHS/CBP Geospatial Vision is to achieve a comprehensive geospatial environment that unifies and supports all mission and business operations with a cohesive approach that includes common operating standards and governance. All geospatial implementations shall comply with the policies and requirements set forth for the DHS Geospatial Information Infrastructure (GII). This includes submission to the Enterprise Architecture Board, or their designee, for review and approval of insertion of hardware, software, services, appliances, and/or structural metadata into the Homeland Security Enterprise Architecture HLS EA.
- g) Ensure that all software developed be digitally signed, compiled, and source controlled in CBP's DevOps (DOIT) environment and/or CBP Amazon Web Services Cloud East (CACE) environment for Cloud hosted solutions.
- h) CBP business shall be conducted on the CBP network using CBP issued desktop or laptop computers, and CBP email. All data captured and applications developed under the TO shall be stored securely on CBP equipment.
- i) Change Management – The contractor shall follow and comply with all CBP OIT and PSPD Change Management processes and procedures to implement software and hardware changes to production systems and applications.
- j) The contractor shall provide full access and cooperation for all activities determined by the Government to be required to ensure an effective incident response, including providing all requested images, log files, and event information to facilitate rapid resolution of sensitive information incidents.

- k) The contractor shall provide support for the CBP Information System Security Officer (ISSO) and program stakeholders to comply with CBP procedures, policies and requirements.

#### 8.2.3 *DHS-CBP Enterprise Architecture Compliance Requirements*

- a) The contractor shall ensure that the design conforms to the Department of Homeland Security (DHS) and Customs and Border Protection (CBP) Enterprise Architecture (EA), the DHS and CBP Technical Reference Models (TRM), and all DHS and CBP policies and guidelines (such as the CBP information Technology Enterprise Principles and the DHS Service Oriented Architecture – Technical Framework), as promulgated by the DHS and CBP Chief Information Officers (CIO), Chief Technology Officers (CTO) and Chief Architect (CA).
- b) The contractor shall conform to the Federal Enterprise Architecture (FEA) model and the DHS and CBP versions of the FEA model, as described in their respective EAs. All models will be submitted using Business Process Modeling Notation (BPMN 1.1 or BPMN 2.0 when available) and the CBP Architectural Modeling Standards. Universal Modeling Language (UML2) may be used for infrastructure only. Data semantics shall be in conformance with the National Information Exchange Model (NIEM). Development solutions will also ensure compliance with the current version of the DHS and CBP target architectures.
- c) Where possible, the contractor shall use DHS/CBP approved products, standards, services, and profiles, as reflected by the hardware, software, application, and infrastructure components of the DHS/CBP TRM/standards profile. If new hardware, software, or infrastructure components are required to develop, test, or implement the program, these products will be coordinated through the DHS and CBP formal Technology Insertion (TI) process (to include a trade study with no less than four alternatives, one of which reflecting the status quo and another reflecting multi-agency collaboration). The DHS/CBP TRM/standards profile will be updated as TIs are resolved.
- d) All developed solutions shall be compliant with the Homeland Security (HLS) EA. All IT hardware and software shall be compliant with the HLS EA.
- e) Compliance with the HLS EA shall be derived from an aligned through the CBP EA.
- f) Description information for all data assets, information exchanges and data standards, whether adopted or developed, shall be submitted to the Enterprise Data Management Office (EDMO) for review, approval, and insertion into the DHS Data Reference Model and Enterprise Architecture Information Repository.
- g) Development of data assets, information exchanges, and data standards will comply with the DHS Data Management Policy MD 103-01. All data-related artifacts will be developed and validated according to DHS Data Management Architectural Guidelines.
- h) Applicability of Internet Protocol version 6 (IPv6) to DHS-related components (networks, infrastructure, and applications) specific to individual acquisitions shall be in accordance with the DHS EA (per OMB Memorandum M-05-22, August 2, 2005) “Selecting Products and Capabilities”, regardless of whether the acquisition is for modification, upgrade, or replacement. All EA related component acquisitions shall be IPv6 compliant, as defined in the USGv6 Profile (NIST Special Publication 500-267) and the corresponding declarations of conformance, defined in the USGv6 Test Program.
- i) In compliance with OMB mandates, all network hardware provided under the scope of



this Statement of Work and associated Contracts shall be IPv6 compatible without modification, upgrade, or replacement.

## **9.0 Accessibility Requirements (Section 508 Compliance)**

Section 508 of the Rehabilitation Act (classified to [29 U.S.C. § 794d](#)) requires that when Federal agencies develop, procure, maintain, or use information and communications technology (ICT), it shall be accessible to people with disabilities. Federal employees and members of the public with disabilities must be afforded access to and use of information and data comparable to that of Federal employees and members of the public without disabilities.

All products, platforms and services delivered as part of this work statement that, by definition, are deemed ICT shall conform to the revised regulatory implementation of Section 508 Standards, which are located at 36 C.F.R. § 1194.1 & Appendixes A, C & D, and available at <https://www.ecfr.gov/cgi-bin/text-idx?SID=e1c6735e25593339a9db63534259d8ec&mc=true&node=pt36.3.1194&rgn=div5>. In the revised regulation, ICT replaced the term electronic and information technology (EIT) used in the original 508 standards. ICT includes IT and other equipment.

Exceptions for this work statement have been determined by DHS and only the exceptions described herein may be applied. Any request for additional exceptions shall be sent to the Contracting Officer and a determination will be made according to DHS Directive 139-05, Office of Accessible Systems and Technology, dated November 12, 2018 and DHS Instruction 139-05-001, Managing the Accessible Systems and Technology Program, dated November 20, 2018, or any successor publication.

### **9.1 Section 508 Requirements for Technology Services**

When providing installation, configuration or integration services for ICT, the Contractor shall not reduce the original ICT item's level of Section 508 conformance prior to the services being performed.

- a) When providing maintenance upgrades, substitutions, and replacements to ICT, the contractor shall not reduce the original ICT's level of Section 508 conformance prior to upgrade, substitution or replacement. The agency reserves the right to request an Accessibility Conformance Report (ACR) for proposed upgrades, substitutions and replacements prior to acceptance. The ACR should be created using the on the Voluntary Product Accessibility Template Version 2.2 508 (or successor versions). The template can be located at <https://www.itic.org/policy/accessibility/vpat>
- b) When providing cloud hosting services (Infrastructure as a Service, Platform as a Service, Software as a Service, etc.) the Contractor shall ensure user administrative screens, dashboards and portals used to configure, and monitor cloud services conform to the Section 508 standards.
- c) The Contractor shall ensure cloud hosting services shall not reduce the level of Section 508 conformance for ICT migrated by DHS to the cloud hosting environment.
- d) When developing or modifying ICT, the Contractor is required to validate ICT deliverables for conformance to the applicable Section 508 requirements. Validation shall occur on a frequency that ensures Section 508 requirements is evaluated within each iteration and release that contains user interface functionality.
- e) When modifying, installing, configuring or integrating commercially available or government-owned ICT, the Contractor shall not reduce the original ICT Item's level of Section 508 conformance.

- f) When developing or modifying web based and electronic content components, except for electronic documents and non-fillable forms provided in a Microsoft Office or Adobe PDF format, the Contractor shall demonstrate conformance to the applicable Section 508 standards (including WCAG 2.0 Level A and AA Success Criteria) by conducting testing using the DHS Trusted Tester for Web Methodology Version 5.0 or successor versions, and shall ensure testing is conducted by individuals who are certified by DHS on version 5.0 or successor versions (e.g. “DHS Certified Trusted Testers”). The Contractor shall provide the Trusted Tester Certification IDs to DHS upon request. Information on the DHS Trusted Tester for Web Methodology Version 5.0, related test tools, test reporting, training, and tester certification requirements is published at <https://www.dhs.gov/trusted-tester>.
- g) When developing or modifying electronic documents and forms provided in a Microsoft Office or Adobe PDF format, the Contractor shall demonstrate conformance to the applicable Section 508 standards (including WCAG Level A and AA Level 2.0 Success Criteria) by conducting testing using the test methods published under “Accessibility Tests for Documents” at <https://www.dhs.gov/compliance-test-processes>.
- h) When developing or modifying ICT deliverables that contain the ability to automatically generate electronic documents and forms in Microsoft Office and Adobe formats, or when the capability is provided to enable end users to design and author web based electronic content (i.e. surveys, dashboards, charts, data visualizations, etc.), the Contractor shall demonstrate the ability to ensure these outputs conform to the applicable Section 508 standards (including WCAG 2.0 Level A and AA Success Criteria). The Contractor shall demonstrate conformance by conducting testing and reporting test results based on representative sample outputs. For outputs produced as Microsoft Office and Adobe PDF file formats, the Contractor shall use the test methods published under “Accessibility Tests for Documents”, which are published at <https://www.dhs.gov/compliance-test-processes>. For outputs produced as web based electronic content, the Contractor shall use the DHS Trusted Tester for Web Methodology Version 5.0, or successor versions. This methodology is published at <https://www.dhs.gov/trusted-tester>
- i) When developing or modifying software functions of ICT, the Contractor shall demonstrate conformance to the applicable Section 508 standards (including the requirements in Chapter 5 and WCAG 2.0 Level A and AA Success Criteria). When the requirements in Chapter 5 do not address one or more software functions, the Contractor shall demonstrate conformance to the Functional Performance Criteria specified in Chapter 3. The Contractor shall use a test process capable of validating conformance to all applicable Section 508 standards for software functionality delivered pursuant to this contract. The Contractor may utilize the DHS Trusted Tester Methodology for Web and Software Version 4.0 as a component of the overall test process used. This version of the test process provides partial test coverage of the Section 508 standards that apply to software. If the Contractor uses this test process, the Contractor shall address the test coverage gaps through additional test procedures. Information on the DHS Trusted Tester Methodology for Web and Software Version 4.0, including coverage against the applicable Section 508 standards for software as well as gaps that need to be addressed through other test methods, related test tools, and training is published at <https://www.dhs.gov/trusted-tester>.
- j) Contractor personnel shall possess the knowledge, skills and abilities necessary to address the accessibility requirements in this work statement.

## 9.2 **Section 508 Deliverables**

- a) **Section 508 Test Plans:** When developing or modifying ICT pursuant to this contract, the Contractor shall provide a detailed Section 508 Conformance Test Plan. The Test Plan shall describe the scope of components that will be tested, an explanation of the test process that will be used, when testing will be conducted during the project development life cycle, who will conduct the testing, how test results will be reported, and any key assumptions.
- b) **Section 508 Test Results:** When developing or modifying ICT pursuant to this contract, the Contractor shall provide test results in accordance with the Section 508 Requirements for Technology Services provided in this solicitation.
- c) **Section 508 Accessibility Conformance Reports:** For each ICT item offered through this contract (including commercially available products, and solutions consisting of ICT that are developed or modified pursuant to this contract), the Offeror shall provide an Accessibility Conformance Report (ACR) to document conformance claims against the applicable Section 508 standards. The ACR shall be based on the Voluntary Product Accessibility Template Version 2.0 508 (or successor versions). The template can be found at <https://www.itic.org/policy/accessibility/vpat>. Each ACR shall be completed by following all of the instructions provided in the template, including an explanation of the validation method used as a basis for the conformance claims in the report.
- d) **Other Section 508 Documentation:** The following documentation shall be provided upon request for ICT items offered through this contract:
  - o Documentation of features provided to help achieve accessibility and usability for people with disabilities.
  - o Documentation on how to configure and install the ICT Item to support accessibility.
  - o Documentation of core functions that cannot be accessed by persons with disabilities.
  - o Documentation of remediation plans to address non-conformance to the Section 508 standards

## 10.0 **DHS Information Technology Portfolio Alignment**

The system shall align with the DHS IT Portfolio below:

- a) **Screening/Watchlist/Credentialing** includes all activities that support the tracking and monitoring of conveyances and cargo crossing U.S. borders, and traffic pattern analysis, database (Federal, State, and Local) linking and querying, and managing status verification and tracking systems. Different investments and systems may support distinct screening and watchlist activities for entities, cargo, and tangible goods. Credentialing encompasses all activities that determine an entities eligibility for a particular license, privilege, or status, from application for the credential through issuance, use, and potential revocation of the issued credential.